

1. Ambito operativo

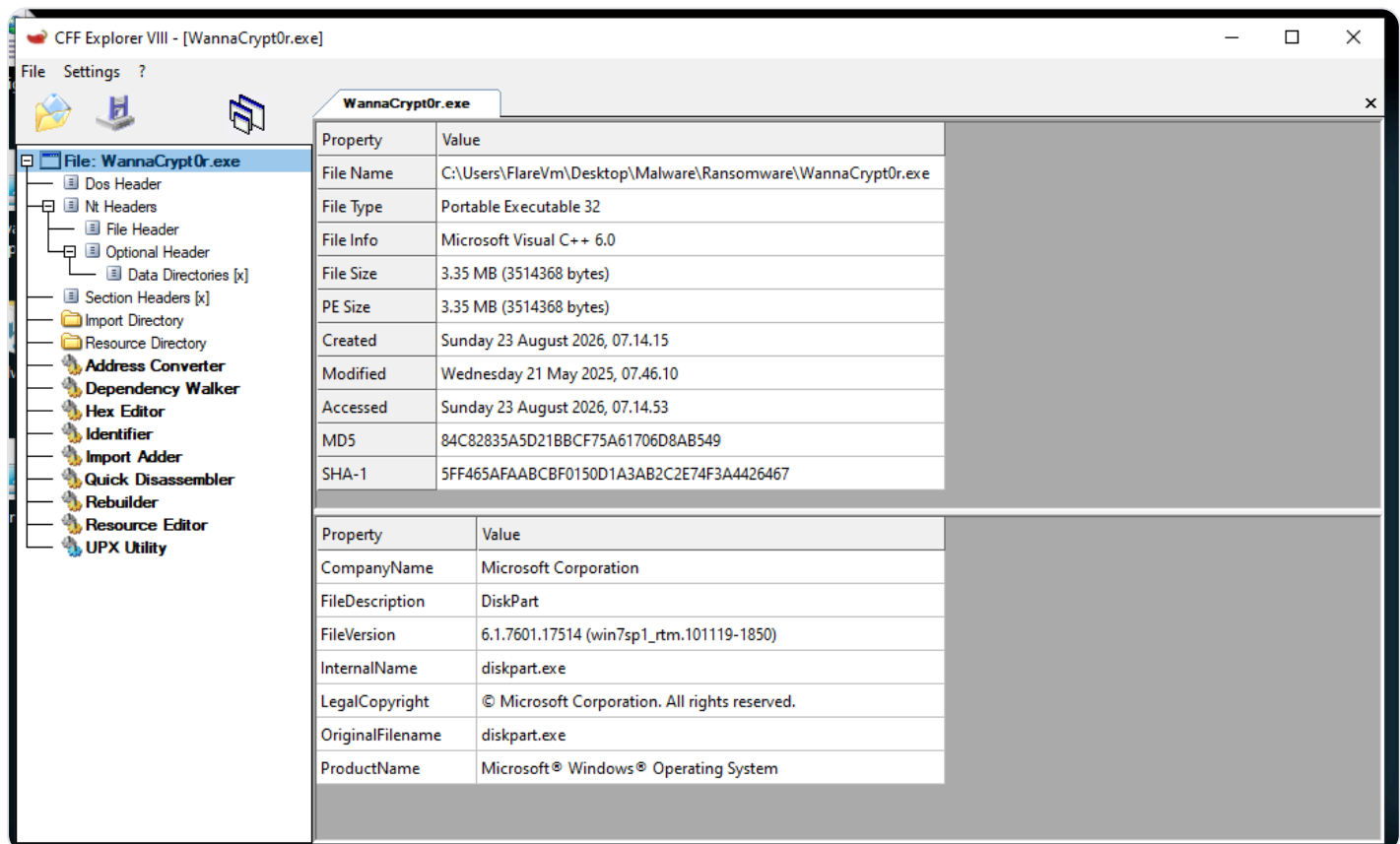
Per questo laboratorio sono nell'ambito operativo le attività di analisi del malware *ransomware* WannaCryptor, e il suo eseguibile `WannaCrypt0r.exe`.

Nell'analisi statica sono state analizzate le chiamate a funzioni dello stesso eseguibile, o di chiamate a librerie dinamiche (DLL) esterne, definite nello stack di esecuzione tramite i software CFF Explorer, o *Common File Format Explorer*, e PE-Studio nell'ambiente isolato virtualizzato "FlareVM". Come analisi successiva, ovvero di analisi dinamica, si è analizzato il comportamento del malware nel tempo di esecuzione, o *runtime*, dell'eseguibile nell'ambiente *Sandbox on-cloud* tria.ge

2. Identificatori del malware

L'analisi del malware ha ritornato la riconducibilità tramite la stringa di *checksum* MD5

`5FF465AFAABCBF0150D1A3AB2C2E74F3A4426467` e la stringa di integrità *hash SHA-1* `84C82835A5D21BBCF75A61706D8AB549`. Queste stringhe sono difatti riconducibili al malware WannaCryptor, e il suo eseguibile `WannaCrypt0r.exe`.



Schermata della finestra del software di analisi PE *CFF Explorer VII* che presenta caricato l'eseguibile `WannaCrypt0r.exe` (del malware WannaCryptor). Da questa schemata si può notare inoltre che il malware usa riferimenti alla linea di comando di gestione dei dischi `diskpart.exe` presumibilmente come tecnica di *masquerading* per tentare di superare i controlli superficiali presentandosi visivamente come un eseguibile non malevolo

3. Analisi statica

3.1. Librerie

Relativamente alle librerie dinamiche (DLL) esterne risultano riferimenti a librerie dinamiche (DLL) di sistema Windows NT, particolarmente le librerie `KERNEL32.dll`, `MSVCRT.dll`, `ADVAPI32.dll` e `USER32.dll`:

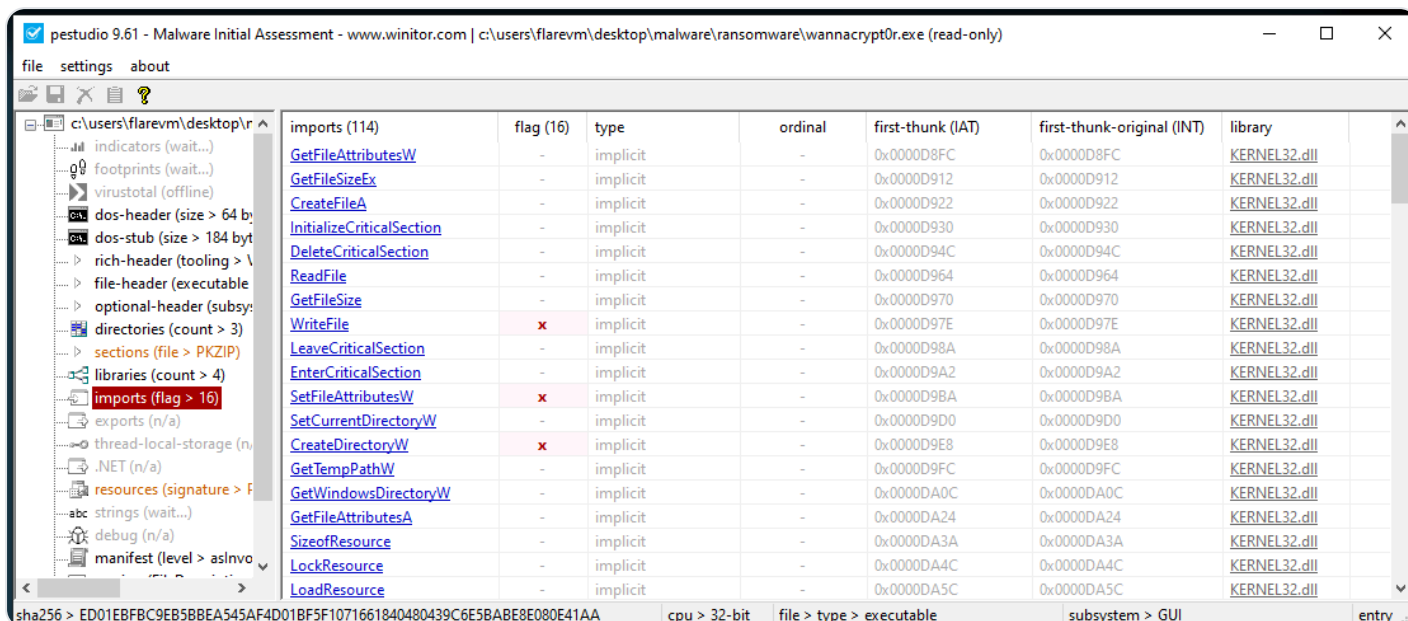
Nome della libreria dinamica	Conteggio riferimenti	Descrizione della libreria
<code>KERNEL32.dll</code>	54	Gestisce le funzioni base del sistema operativo. È responsabile della gestione della memoria, dei processi, dei thread, delle operazioni di I/O (Input/Output) e dell'accesso ai file e ai dispositivi del sistema.
<code>MSVCRT.dll</code>	49	Nominata anche come <i>Microsoft Visual C++ Runtime</i> , contiene la libreria di runtime standard per i programmi scritti in C e C++. Fornisce funzioni comuni come l'allocazione della memoria, tra cui la funzione <code>malloc</code> , la gestione delle stringhe e la manipolazione dei dati di base
<code>ADVAPI32.dll</code>	10	Nominata anche come <i>Advanced API 32-bit</i> , gestisce le funzionalità avanzate del sistema operativo. Tra queste rientrano la sicurezza di Windows, la gestione degli utenti, la crittografia e l'accesso o modifica del Registro di sistema
<code>USER32.dll</code>	1	Si occupa dell'interfaccia utente grafica (GUI). Gestisce la creazione e il controllo di finestre, menu, pulsanti e la ricezione degli input dell'utente da mouse e tastiera.

3.2. Importazioni

L'analisi dell'*Import Address Table* (IAT) tramite PEStudio evidenzia la dipendenza del binario da un totale 114 funzioni/moduli delle seguenti librerie dinamiche, o DLL (per ogni libreria seguono le funzioni/moduli rilevanti):

- Libreria `KERNEL32.dll`: Dal conteggio di 54 funzioni importate, risultano rilevanti i riferimenti alle funzioni `VirtualAlloc`, `VirtualProtect` (gestione/modifica dei permessi di memoria dinamica), `CreateProcessA` (esecuzione di comandi/processi), `CreateDirectoryA`, `CreateDirectoryW`, `WriteFile`, `CopyFileA`, `SetFileAttributesW` (manipolazione del file system per la fase di cifra/dropper).
- Libreria `ADVAPI32.dll`: Dal conteggio di 10 funzioni importate, risultano rilevanti i riferimenti alle funzioni `OpenSCManagerA`, `CreateServiceA`, `StartServiceA` (persistenza ed installazione di servizi Windows), `RegCreateKeyW`, `RegSetValueExA` (modifica del registro), `CryptReleaseContext` (gestione del contesto crittografico)
- Libreria `MSVCRT.dll`: Dal conteggio di 49 funzioni importate, risultano rilevanti i riferimenti alle funzioni `rand`, `srand` utilizzati nella generazione di valori pseudocasuali, e presumibilmente utilizzati nella generazione delle chiavi crittografiche o nella cifratura temporanea
- Libreria `USER32.dll`: Risulta il solo riferimento alla funzione `wsprintfA` per la formattazione stringhe lato UI/interfaccia

Tra le funzioni importate, inoltre, il software PEStudio contrassegna come "flagged" (sospette) 16 riferimenti a metodi/funzioni dall'eseguibile del malware.



Schermata del pannello degli imports della finestra del software di analisi PE *PE Studio* che presenta caricato l'eseguibile `WannaCrypt0r.exe` (del malware WannaCryptor).

3.3. Risorse interne

Dall'analisi statica delle risorse interne del malware (visibili nel software *CFF Explorer VII* nel pannello "*Resource Editor*") si è notata la presenza dell'archivio in formato ZIP (per la firma `50 4B 03 04`) incorporato nell'eseguibile come risorsa "XIA". Questo archivio ospita l'archivio compresso contenente i file di supporto del ransomware, e tra la sequenza esadecimale, decodificata in ASCII, del binario dell'eseguibile si sono notati i seguenti riferimenti di file: `b.wnry`, `c.wnry`, `r.wnry`, `s.wnry`, `t.wnry`, `u.wnry`, `taskdl.exe`, `taskse.exe` e `msg`.

4. Analisi dinamica in ambiente *tria.ge*

Per l'analisi dinamica, ovvero l'analisi dell'esecuzione del campione di malware all'interno di un ambiente controllato ed isolato (sandbox), si è utilizzata la piattaforma di analisi sandbox *Hatching Triage*, o *tria.ge*, che esegue il campione del malware in un ambiente automatizzato di analisi, rilevando:

- gli indicatori di compromissione (IoC)
- le configurazioni estratte dalla memoria
- il comportamento osservato, che viene mappato sulla matrice *MITRE ATT&CK*

Durante l'esecuzione, Triage ha assegnato al campione un punteggio di pericolosità di 10/10 e lo ha classificato con certezza come appartenente alla famiglia *WannaCry*.

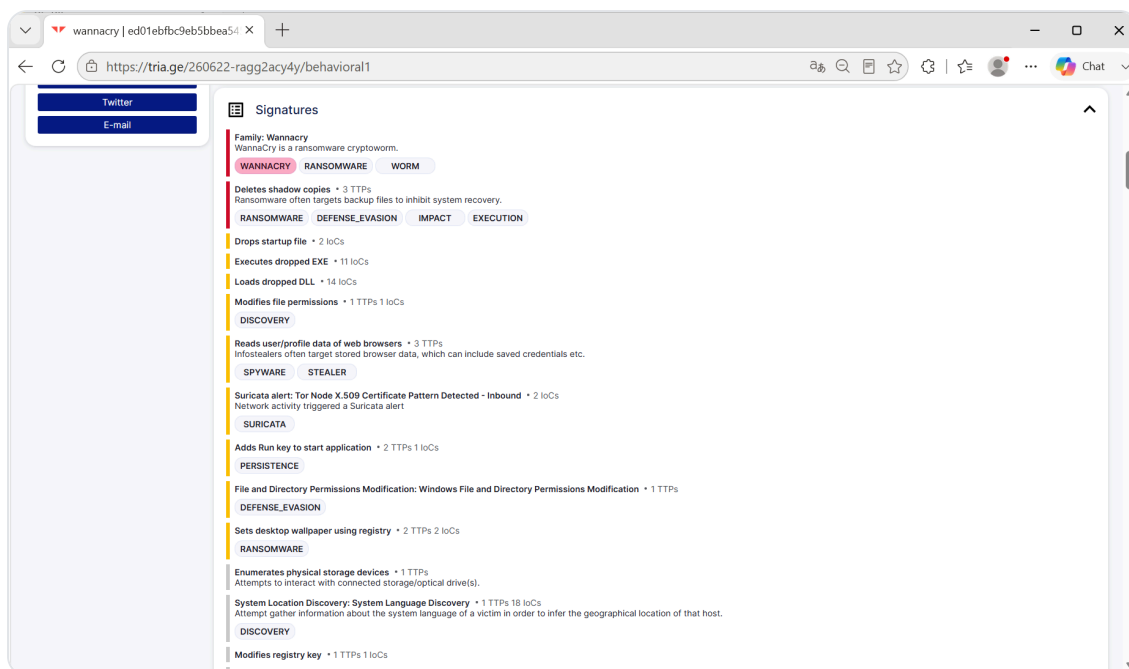
4.1. Tattiche, tecniche e procedure del malware (TTP)

Al termine dell'analisi, la piattaforma ha attribuito i tag *ransomware*, *worm*, *spyware* e *stealer*, identificandolo vettore di attività malevole riconducibili a diverse tattiche della matrice MITRE:

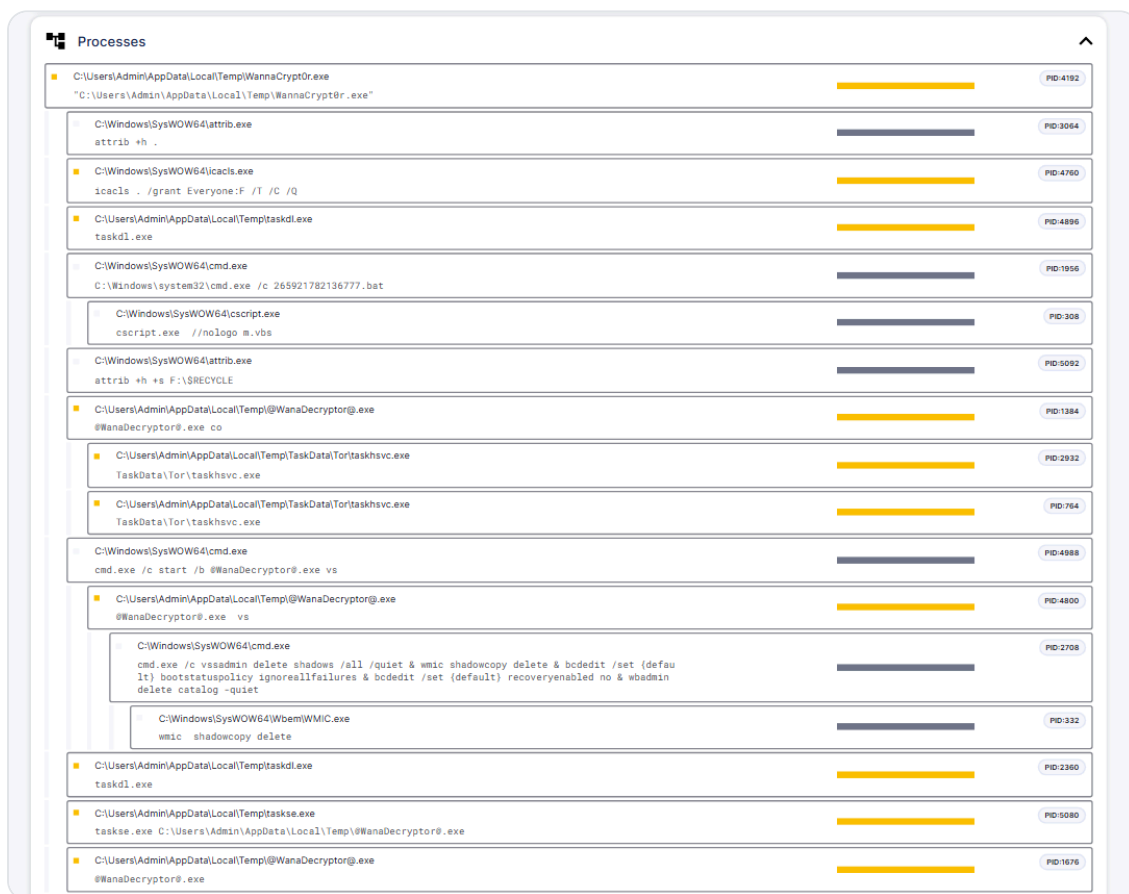
Tattica	Attività registrate
<i>Impact</i>	Alterazione visiva dell'interfaccia/sfondo tramite Defacement (T1491) e inibizione del ripristino del sistema (T1490), bloccando i meccanismi di recovery di Windows.
<i>Persistence & Privilege Escalation</i>	Configurazione di chiavi di autorun nel Registro di sistema e cartelle di avvio automatico (T1547, T1547.001) per garantire il persistere del malware al riavvio del sistema.
<i>Defense Evasion</i>	Manipolazione dei permessi su file e directory (T1222, T1222.001), occultamento di risorse tramite attributi nascosti (T1564, T1564.001), eliminazione di tracce e file (T1070, T1070.004) e modifica delle chiavi di registro (T1112)
<i>Discovery</i>	Identificazione delle informazioni sul sistema operativo (T1082) e riconoscimento delle impostazioni locali di lingua e geolocalizzazione del sistema (T1614, T1614.001).
<i>Execution</i>	Utilizzo di Windows Management Instrumentation (T1047) per l'esecuzione di comandi di sistema

Inoltre, nella collezione delle manifestazioni del malware durante l'esecuzione in ambiente sandbox isolato sono stati visibili i seguenti comportamenti:

- Modifica dei permessi/liste di controllo di accesso dei file tramite la linea di comando `icaccls.exe`
- Utilizzo della funzione *AdjustPrivilegeToken*, presumibilmente per l'abilitazione di privilegi/permessi per la propagazione del malware ai dispositivi della rete SMB con l'exploit EternalBlue (CVE-2017-0144).
- Eliminazione delle istantanee (o *shadow copies*) dei files e disabilitazione del servizio "*Copia Shadow del volume*" (o "*Volume Shadow Copy*", VSS) allo scopo di impedire il ripristino dei file criptati dall'eseguibile del malware `WannaCrypt0r.exe` ;
- Sostituzione dello sfondo del desktop tramite modifica del registro di sistema con il file `@WanaDecryptor@.bmp` , estratto dal file `b.wnry` dell'archivio localizzato all'interno dell'eseguibile del malware.
- Aggiunta dell'eseguibile tra l'elenco di programmi che il sistema esegue all'avvio del sistema, con la creazione di un file nella cartella `Startup` , e con la definizione di una nuova chiave `Run` nel registro di sistema.
- Esecuzione dei file `.exe` e `.11` estratti (dropped), lancio di un comando tramite `cmd.exe`, e avvio di uno script `VBScript`, per l'estrazione del payload dal settore `.rsrc` .
- Modifica i permessi di file e cartelle tramite `icaccls.exe` e funzione `AdjustPrivilegeToken` (53 IoC).
- Rilevazione la lingua di sistema (o cultura), ed enumerazione dei dispositivi di archiviazione e processi in esecuzione.
- Eliminazione delle shadow copies e usa il servizio Volume Shadow Copy per impedire il ripristino dei file;
- Impostazione lo sfondo del desktop con la nota di riscatto.



Schermata delle firme rilevate da un analisi dinamica del malware WannaCryptor in ambiente sandbox isolato tria.ge



Schermata dei primi processi, e relativi comandi, eseguiti rilevati da un analisi dinamica del malware WannaCryptor in ambiente sandbox isolato tria.ge

4.2. Eventi di Rete e Connessioni Command & Control (C2)

Dall'analisi del flusso di esecuzione delle chiamate di rete, l'attività del malware risulta strettamente correlata ai processi di sistema e all'infrastruttura di rete locale. In particolare, si notano i seguenti comportamenti:

- Nel tracciato dinamico si osserva una singola interazione di rete registrata al timestamp 375 da parte del processo `svchost.exe`, il quale gestisce il servizio di risoluzione nomi `Dnscache`, con il comando `C:\Windows\system32\svchost.exe -k NetworkService -p -s Dnscache`.
- Durante la finestra di esecuzione analizzata in sandbox, il processo principale del ransomware `WannaCrypt0r.exe` non stabilisce sessioni TCP/UDP dirette e persistenti con server Command & Control esterni. L'attività di rete è delegata all'infrastruttura DNS di sistema (`Dnscache`), comportamento tipico delle fasi preliminari di ricognizione o tentativi di risoluzione del dominio "*kill-switch*" (caratteristico della famiglia WannaCry) prima di procedere con le routine di cifratura locali.

4.3. Eventi nel registro di Windows

I risultati dell'esecuzione del malware ransomware nell'ambiente di sandbox [tria.ge](#) mostrano un notevole numero di eventi di ricerca/enumerazione della chiave (`QueryKey` e `EnumerateValueKey`), lettura (`OpenKeyEx`) e scrittura (`SetValueKeyStr`) nel registro di Windows. In questo ambiente si sono notati particolarmente la seguente sequenza di eventi:

Controllo dei criteri di sistema e sottostistema

- **1** Accesso alle chiavi dei nidi (o *hives*) `HKLM\SYSTEM\ControlSet001\Control\Session Manager` e `HKLM\Software\Microsoft\Wow64\x86`
- **2** Verifica dello stato delle impostazioni di avvio sicuro (`HKLM\SYSTEM\ControlSet001\Control\SafeBoot\Option`) e dei criteri di esecuzione del codice e `AppLocker` (`HKLM\SOFTWARE\WOW6432Node\Policies\Microsoft\Windows\Safer\CodeIdentifiers`)

Identificazione della cultura del sistema

- **3** Attraverso l'uso iterativo di `OpenKeyEx` e `QueryKey` sulla chiave `HKLM\SYSTEM\ControlSet001\Control\MUI\UILanguages`, il malware interroga il registro alla ricerca del linguaggio di interfaccia utente, e registra l'apertura e la verifica di diverse sottochiavi relative alle lingue supportate, necessarie al ransomware per determinare la versione localizzata del pacchetto di riscatto (`msg/m_<language>.wnry`) da mostrare alla vittima.

Controllo Crypto e policies di sicurezza di Local Security Authority (LSA)

- **4** Attraverso chiamate `OpenKeyEx` sulle chiavi `HKLM\SYSTEM\ControlSet001\Control\Lsa\FipsAlgorithmPolicy` e `HKLM\SYSTEM\ControlSet001\Control\Cryptography\Providers` è rilevata la presenza di provider di crittografia e la conformità *Federal Information Processing Standards* (FIPS), ovvero agli algoritmi crittografici approvati dal governo degli Stati Uniti (standard FIPS 140-2 o 140-3).

Enumerazione dell'interfaccia utente multilingua (MUI)

- **5** Per ciascuna lingua identificata nel registro di sistema sotto il percorso `HKLM\SYSTEM\ControlSet001\Control\MUI\UILanguages<locale>`, `WannaCrypt0r.exe` invoca sequenze consecutive dell'operazione `EnumerateValueKey`, per l'estrazione e verifica dei parametri associati alle risorse MUI propedeutici all'estrazione e creazione dei file del kit di riscatto nella directory `%TEMP%`.

Creazione dello hive del malware

- **6** Il processo del malware crea il nuovo nido (o *hive*) `HKLM\Software\WOW6432Node\WanaCrypt0r`, e, successivamente crea in questo nido la chiave `wd` per il salvataggio della stringa del percorso della *directory* di lavoro, e per orchestrare la successiva esecuzione dei componenti accessori (`taskdl.exe`, `taskse.exe`).